

Computer Incident Response Ethical Decision Making

Case studies developed by Christina Ayiotis, Esq., CRM, Co-Chair, Georgetown Cybersecurity Law Institute, using materials written by Aaron Burstein, Esq., Policy Advisor, NTIA; Randy V. Sabett, J.D., CISSP, Counsel, ZwillGen PLLC; Shane McGee, Esq., General Counsel & VP of Legal Affairs, MANDIANT Corporation; and Anand Shah, Esq., Deputy Attorney General, Division of Criminal Justice – Cyber, State of New Jersey Office of the Attorney General

Agenda

- Welcome and Introduction of Panelists
- Scenario Instructions
- Breakout into teams
Discuss Scenarios
- Report observations back to full group
- Feed back from panel members on team observations

Panel Members

- **Luke McCormack**/Moderator (Dir USCC)
- **Beth Cappello**, Former DHS HQ & Mgt CIO
- **Brian Z. Mund** Senior Counsel, Criminal Division Computer Crime and Intellectual Property Section, DOJ

Scenario Instructions

1. As a Group, think about the various roles involved in the Scenario. Think beyond Roles specifically mentioned in the Scenario – attorney's etc. Take a moment to think about who is affected by the event.
2. Then, focusing on the Primary Role, discuss considerations and distinctions
3. Be prepared to present Group's decisions to other Groups

Primary Role Considerations

1. What your interests in this Scenario are
2. What, if any, your obligations are
 - a) What the authority for those obligations is
 - b) If any of your obligations are contradictory
3. The risks the Incident pose (and list them)
 - a) How you could minimize those risks and/or mitigate their consequences
4. Any opportunities created by the Events (and list them) –lessons learned etc.

Role Distinctions

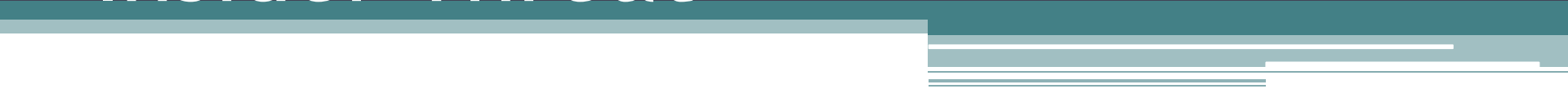
- What actions **must** you take?
 - What legal/compliance requirements are you following?
- What actions **could** you take?
 - What resources might you look to for guidance?
- What actions **should** you take?
 - Which other Roles might have interests that conflict with you in the performance of your duties? Describe the Roles, their interests, and your response.

Suppose you are
GRAND EMPEROR OF THE UNIVERSE,
beholden to no one and no law.

Would you change any of your answers?

Why?

Scenario One: Insider Threat

A series of horizontal lines in teal, light blue, and white, extending from the left edge of the slide and overlapping the white area on the right.

Scenario One

- **Primary Role** – System Administrator at U.S. Government Contractor that does work for the Intelligence Community
- **Request from Legal Department to monitor Potentially Disgruntled Employee** – retrieve and/or forensically image all electronically stored information (ESI) from employee's devices; monitor all E-Mail/Phone/Texting/IM traffic

Scenario One

- **Company Policy** - Every employee during Onboarding process signs a Computer Use Policy that allows Company to monitor all usage; Company also is in the process of implementing a BYOD (Bring Your Own Device) Policy and Employee is in the Pilot Group; BYOD Policy is not clear regarding expectation of privacy of personal data on personally-owned devices that contain Company ESI

Employee Objects to Negative Performance Review

Mr. PITA left his Annual Performance Review very upset muttering under his breath “the Company will pay.” His Manager, Mr. Company Man contacted Legal to inform them of potential retaliatory action he might take. Legal decided to monitor Mr. PITA very closely (physically and electronically).

Description of ESI/Data Flows Discovered through Monitoring

- Company already has Data Loss Prevention Software implemented
- Company use Guidance Software's EnCase Enterprise so can push out servlets to all devices connected to Company Network to begin collecting ESI
- Company installs a keystroke logger on Company Laptop and has captured passwords to personal E-Mail accounts, personal social media accounts and personal banking

Expectation of Privacy

- For the Company-owned laptop, does Mr. PITA have any expectation of privacy?
- If Mr. PITA uses a company-owned device to log in to a personal Social Media account and uses that messaging service to send communications to others regarding his Performance Review, can you collect that ESI?
- If Mr. PITA uses his personally-owned smartphone through the BYOD program, does that change your answer?

Limits to Monitoring

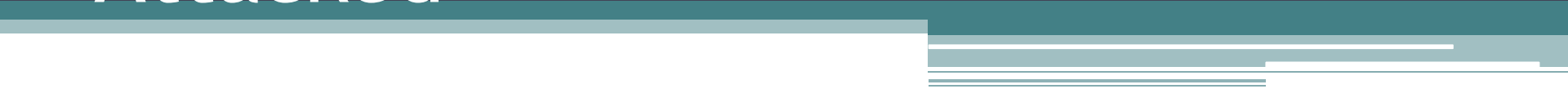
- If Mr. PITA works from home and uses his personally-owned desktop (that his family uses), can you access it and search it? What if you come across pornography (and you know Mr. PITA has a 14-year-old son)—do you collect it so HR can take action? It's not child pornography, so there are no restrictions to personal possession. Can anyone from the Company inform his wife?

Group Discussion

Groups Reconvene for Briefings

Scenario Two

How Far to Go When You're Attacked

A series of horizontal lines in teal and light blue colors, some solid and some dashed, extending across the bottom of the slide.

Scenario Two

- **Primary Role** – Member of the Office of the Chief Information Security Officer of a large multinational professional services firm; formerly worked on forensics for U.S. Military Intelligence
- **Definition of “cyber attack” and “hack back”** – while defending Firm’s network during a DDOS, begin to engage in activities that could be considered “active defense” or “hacking back”

Nature of the Distributed Denial of Service Attack

- Origin of the attack unclear
- Seems to be in response to action taken by C-Suite members that offended Anonymous
- Approaches to determining source of attack:
 - Technical (at least nine types)
 - Operational (observe tactics, techniques and procedures of the adversary)
 - Strategic context surrounding the event

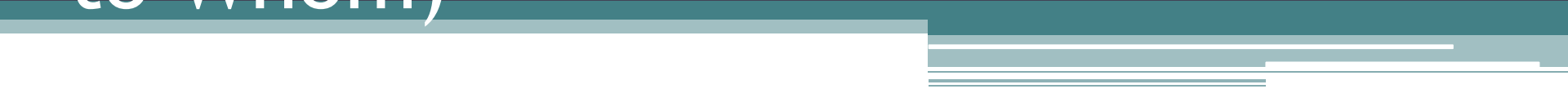
Determining Course of Action

- Which attribution approach should you use and why?
- How do you consider consequences of incorrect attribution?
- If you engage law enforcement, does that shield you from CFAA enforcement action?
- If your actions could pass legal muster, how do you determine proportionality of response?

Group Discussion

Groups Reconvene for Briefings

Scenario Three: When To Report Vulnerabilities (and to Whom)

A series of horizontal lines in teal and light blue colors, of varying lengths, extending from the left edge of the slide towards the right, positioned below the title.

Scenario Three

- **Primary Role** – Security Researcher Detects a Security Vulnerability in a Well-Known Software Product
- **Which (non-contractual) options are available?**
 - **Report to Software Vendor OR Government**
 - What if Government doesn't want to fix but exploit vulnerability; should you go public?
 - **Sell to Software Vendor Under Bug Bounty Program**
 - **Sell to Highest Bidder**
 - Criminals
 - Government
 - CERT
 - Intelligence Service

Determining Course of Action

- If discovery was during the execution of a contract, does the contract have applicable language regarding next steps?
 - If nothing in contract, should Researcher still inform Client?
- If discovery was “by accident,” what is ethical thing to do?
 - Which entity should the Researcher first report to or try to sell to?
 - How soon after discovery and reporting, can Researcher “go public”?

JASBUG Case Study

- Jeff Schmidt (Founder and CEO, JAS Global Advisors LLC)
- In January 2014, Jeff discovered a **critical** vulnerability in Windows and reported it to Microsoft
 - Had the ability to sell knowledge of this to cybercriminals or intelligence services
 - Took Microsoft over a year to fix (was a design problem) and kept issue confidential the whole time

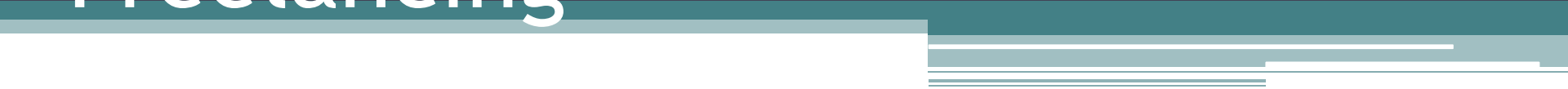
Bug Bounty Programs

- What if Software Company does not offer a bug bounty?
 - Should you still try to sell information about the vulnerability?
 - If Software Company doesn't meet your price, can you sell on the open market?
 - Does it matter who you sell to?

Group Discussion

Groups Reconvene for Briefings

Scenario Four: Freelancing

A series of horizontal lines in teal, light blue, and white, extending from the left edge of the slide and overlapping the white section.

Scenario Four

- **Primary Role** – Security Researcher Has a Good Day Job but is considering Freelancing as a Hacker-for Hire
 - Is it ethical to take a job from a site like HACKER'S LIST (“where people anonymously post bids for someone to steal an E-Mail password, break into a Facebook account or change a school grade”)– hackerslist.com?

Group Discussion

Groups Reconvene for Briefings

Wrap Up